

Relatório de Cibersegurança

Criação de plugin para Firefox para detecção e bloqueio de rastreadores

Aluno	Vinícius Leal da Silva
-------	------------------------

Professor	João Eduardo Luisi
-----------	--------------------

Instituição	Insper
-------------	--------

Ferramenta	PrivacyGuard - Firefox WebExtensions
------------	--------------------------------------

Data dos ensaios	28 de setembro de 2026
------------------	------------------------

Relatório técnico de validação funcional, comparação de resultados e metodologia de pontuação de privacidade.

1. Introdução e arquitetura da ferramenta

A extensão PrivacyGuard foi desenvolvida no padrão Mozilla WebExtensions para auditar tráfego web, identificar vetores de rastreamento e sinalizar alterações potencialmente perigosas no ambiente cliente. O relatório confronta o comportamento observado com páginas padronizadas de teste e com três sites reais: G1, UOL e Mercado Livre.

Componente	Responsabilidade principal
Background service background.js	Monitora requisições via <code>webRequest.onBeforeRequest</code> , compara eTLD+1, inspeciona parâmetros de URL, audita cookies e aplica a lista de bloqueio personalizada.
Injected hook monitor content.js + script no DOM	Intercepta operações de canvas e observa alterações em APIs nativas de rede, como <code>fetch</code> , <code>XMLHttpRequest</code> e <code>WebSocket</code> .
Popup popup.html / popup.js	Exibe métricas por página, ameaças detectadas, score de privacidade e controles para bloqueio personalizado.

Escopo da avaliação

A prova exige a detecção de conexões de terceira parte, classificação de cookies, armazenamento HTML5, cookie sync/bounce tracking, canvas fingerprinting, indicadores de hijacking/hooks, relatório por página, score explícito e lista de bloqueio. Para o conceito A, os resultados devem ser sustentados por prints, HAR e reconciliação com Blacklight e uBlock Origin.

Nota de evidência. Os oito prints recebidos foram incorporados integralmente. Os arquivos HAR e o log/exportação do uBlock Origin não foram fornecidos junto aos anexos; por isso, as contagens de uBlock permanecem identificadas como valores informados no ensaio, e não como dados reprocessados neste relatório.

2. Testes padronizados de privacidade

Foram examinadas cinco situações. Quatro pertencem às Privacy Test Pages associadas ao ecossistema DuckDuckGo; o ensaio de canvas foi realizado no BrowserLeaks, conforme mostra o próprio print. A tabela registra exatamente o que aparece no popup.

Teste	Esperado	Observado no PrivacyGuard	Reconciliação
Tracker Reporting	Carregamento de script de terceiro (bad.third-party.site).	0 conexões; score 100/100.	Divergência. O recurso sintético não chegou à telemetria da extensão. A hipótese compatível com o ensaio é bloqueio anterior pelo Firefox/ETP; deve ser confirmada no HAR e no console de rede.
Storage Blocking	Testar gravação e recuperação por múltiplos mecanismos de armazenamento em contexto de terceira parte.	2 conexões; 5 cookies de 1ª parte, todos persistentes; 0 cookies de 3ª parte; alerta de bounce; score 79/100.	Deteção parcial. As origens foram vistas, mas a classificação dos cookies não refletiu terceiros. O alerta de bounce neste teste sugere falso positivo da heurística de parâmetros/identificadores.
Canvas Fingerprinting	Sinalizar leitura usada para gerar assinatura de canvas.	A página gerou assinatura única, mas o popup mostrou "Canvas Fingerprint: Não"; score 100/100.	Divergência. Possíveis causas: corrida de inicialização ou isolamento entre o mundo da página e o content script. A instrumentação precisa ocorrer em document_start no contexto efetivo da página.
Bounce Tracking	Detectar navegação intermediária com UID transferido por URL/cookie/storage.	A URL contém bounceUID..., porém o popup mostrou "Bounce Tracking / Sync: Não"; score 100/100.	Divergência comprovada pelo print. A regra não correlacionou o redirecionamento ou não persistiu o estado entre abas/navegações.
Query Parameters	Reconhecer parâmetros de clique como fbclid; neutralização é opcional conforme a política da ferramenta.	4 cookies persistentes de 1ª parte; localStorage 1; sessionStorage 1; nenhum alerta de bounce; score 96/100.	A auditoria de storage funcionou, mas o identificador publicitário não foi sinalizado. A opção de não reescrever a URL evita quebra funcional, porém não impede uma indicação passiva ao usuário.

Síntese. Os testes demonstram boa coleta de conexões e armazenamento em alguns cenários, mas também expõem falsos negativos relevantes em canvas e bounce tracking, além de um provável falso positivo no teste de storage. Essa distinção é central: uma ferramenta de segurança deve separar "não observado" de "não ocorreu".

Evidência 2.1 - Tracker Reporting

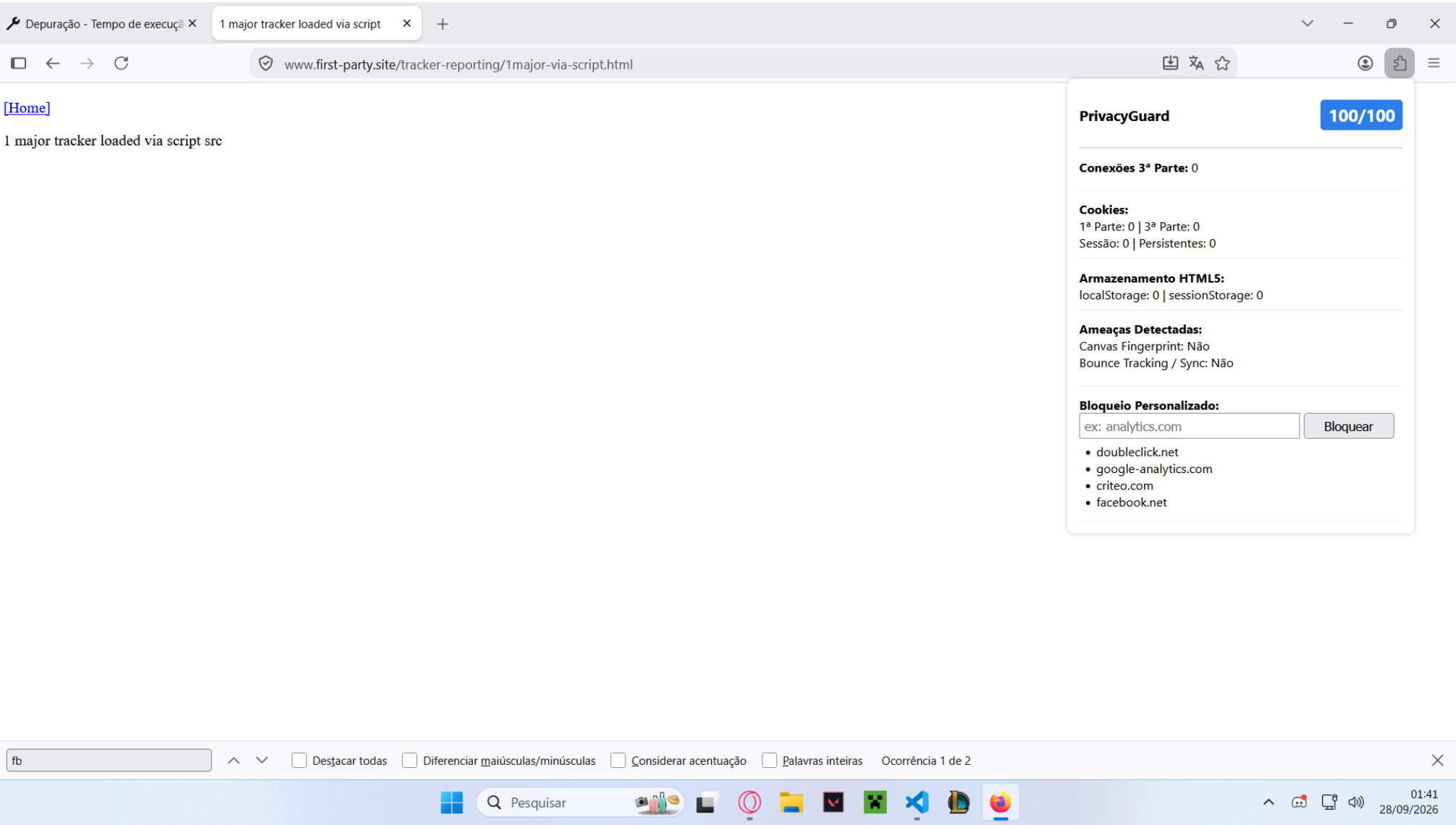


Figura 1. O teste solicita o carregamento de um tracker por script; o PrivacyGuard registra zero conexões de terceira parte.

Evidência 2.2 - Storage Blocking

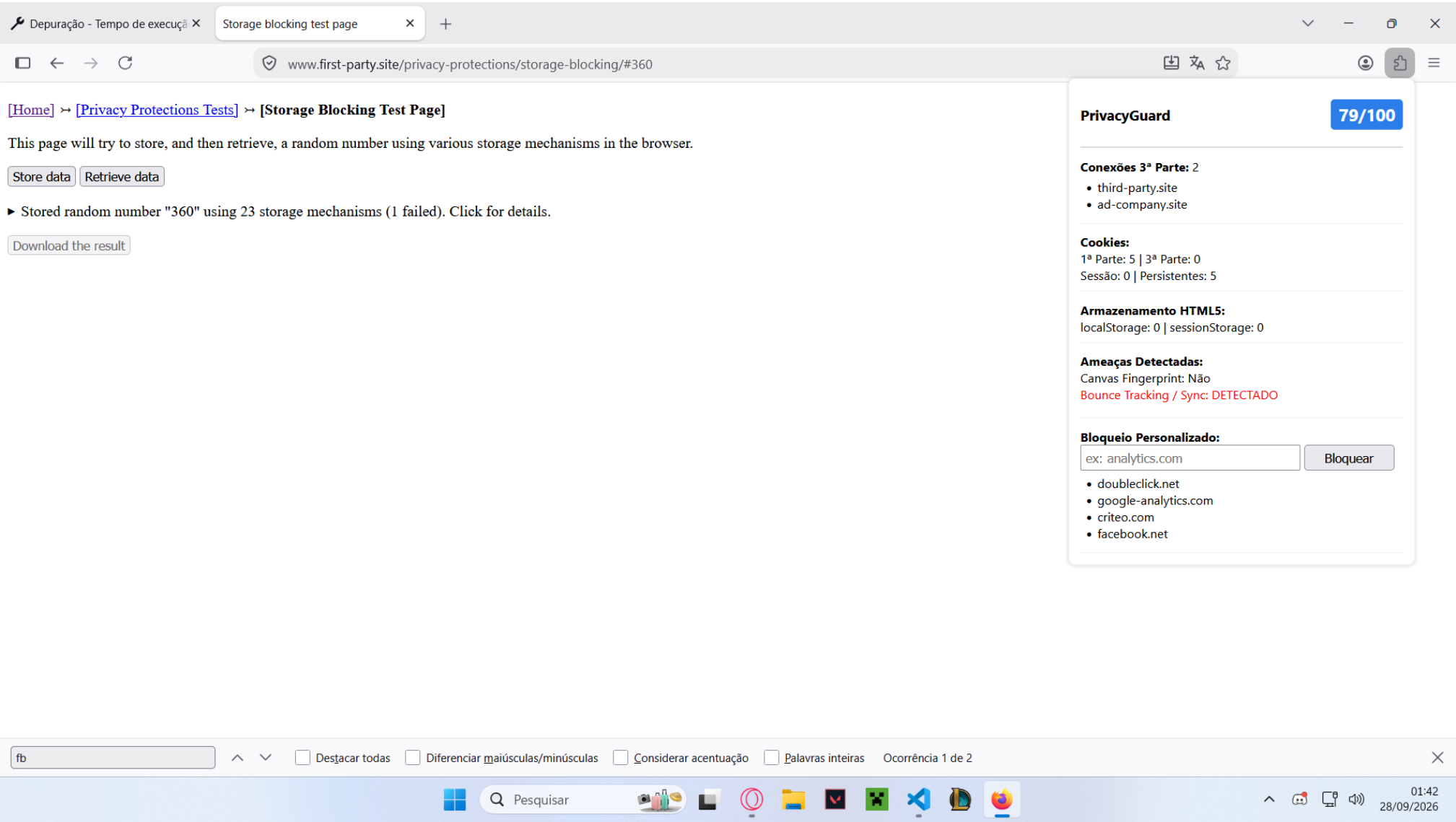


Figura 2. O popup registra duas conexões, cinco cookies persistentes de primeira parte e alerta de bounce tracking.

Evidência 2.3 - Canvas Fingerprinting

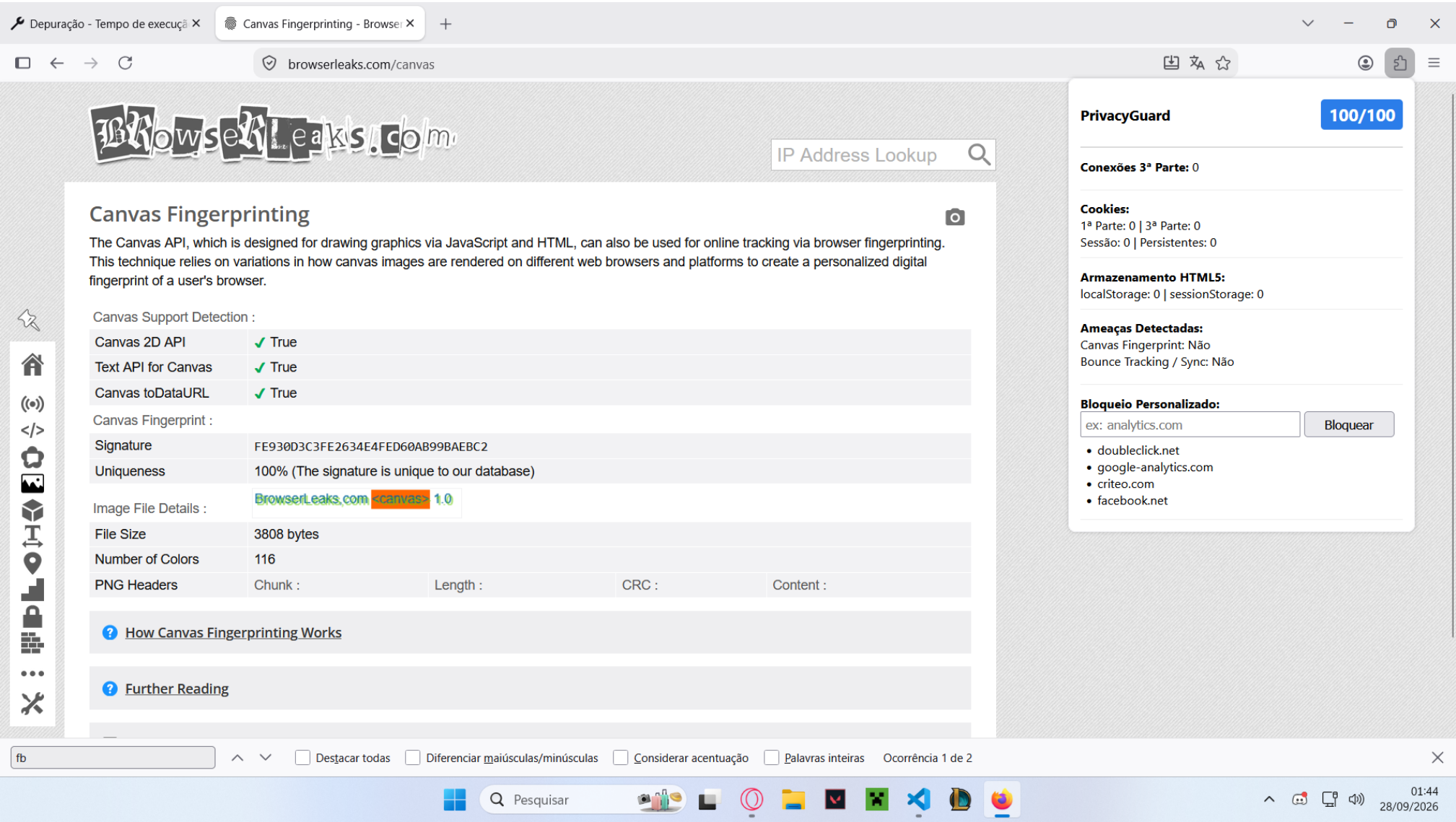


Figura 3. O BrowserLeaks produz assinatura de canvas, enquanto o PrivacyGuard não sinaliza fingerprinting.

Evidência 2.4 - Bounce Tracking

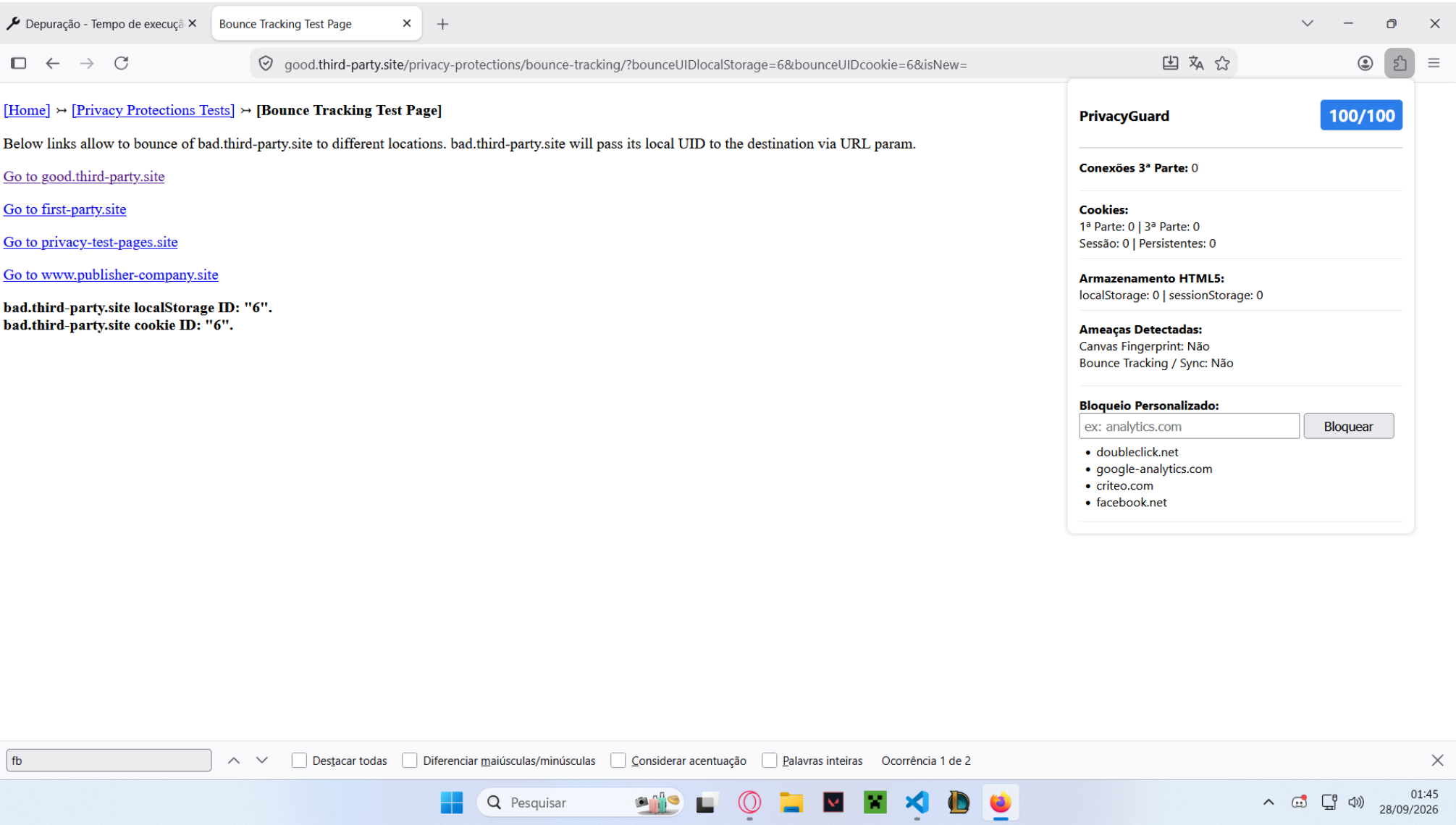


Figura 4. A URL e a página exibem identificadores de bounce, mas o PrivacyGuard mostra “Não”.

Evidência 2.5 - Query Parameters

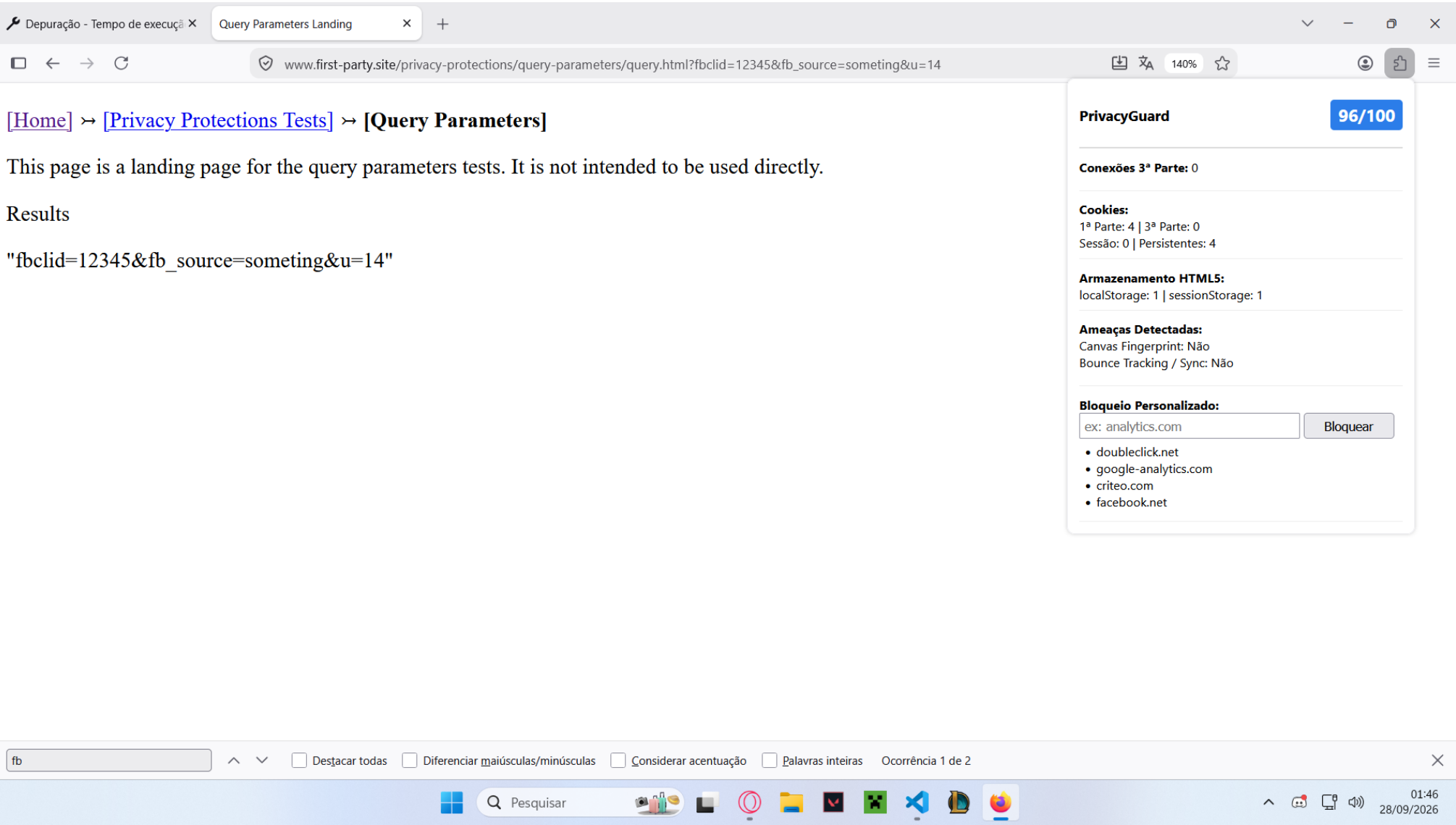


Figura 5. A URL contém fbclid; o popup registra cookies e storage, sem alerta específico para o parâmetro.

3. Análise comparativa em sites reais

A comparação abaixo separa três classes de medida: (i) toda conexão cujo eTLD+1 difere da página, usada pelo PrivacyGuard; (ii) entidades classificadas como publicidade/rastreamento pelo Blacklight; e (iii) requisições bloqueadas por listas do uBlock Origin. As métricas não são intercambiáveis e, portanto, diferenças numéricas não significam automaticamente erro.

Métrica	G1	UOL	Mercado Livre
Conexões 3ª parte - plugin	29	17	11
Cookies - plugin	33 de 1ª parte; 0 de 3ª; 1 sessão; 32 persistentes	0	9 de 1ª parte; 0 de 3ª; 1 sessão; 8 persistentes
Storage HTML5 - plugin	localStorage 23; sessionStorage 7	0 / 0	localStorage 0; sessionStorage 1
Blacklight ad trackers / cookies 3ª parte	27 / 14	67 / 141	0 / 3
uBlock Origin bloqueios informados	~28	~19	~14
Ameaças do plugin	Bounce tracking / sync	Nenhuma no print	Bounce tracking; sobrescrita de fetch e XMLHttpRequest
Privacy Score	45/100	60/100	32/100

Os valores do Blacklight acima foram transcritos dos resultados fornecidos: G1 (27 trackers, 14 cookies), UOL (67, 141) e Mercado Livre (0, 3). Eles substituem as estimativas inicialmente presentes no rascunho.

Evidência 3.1 - G1

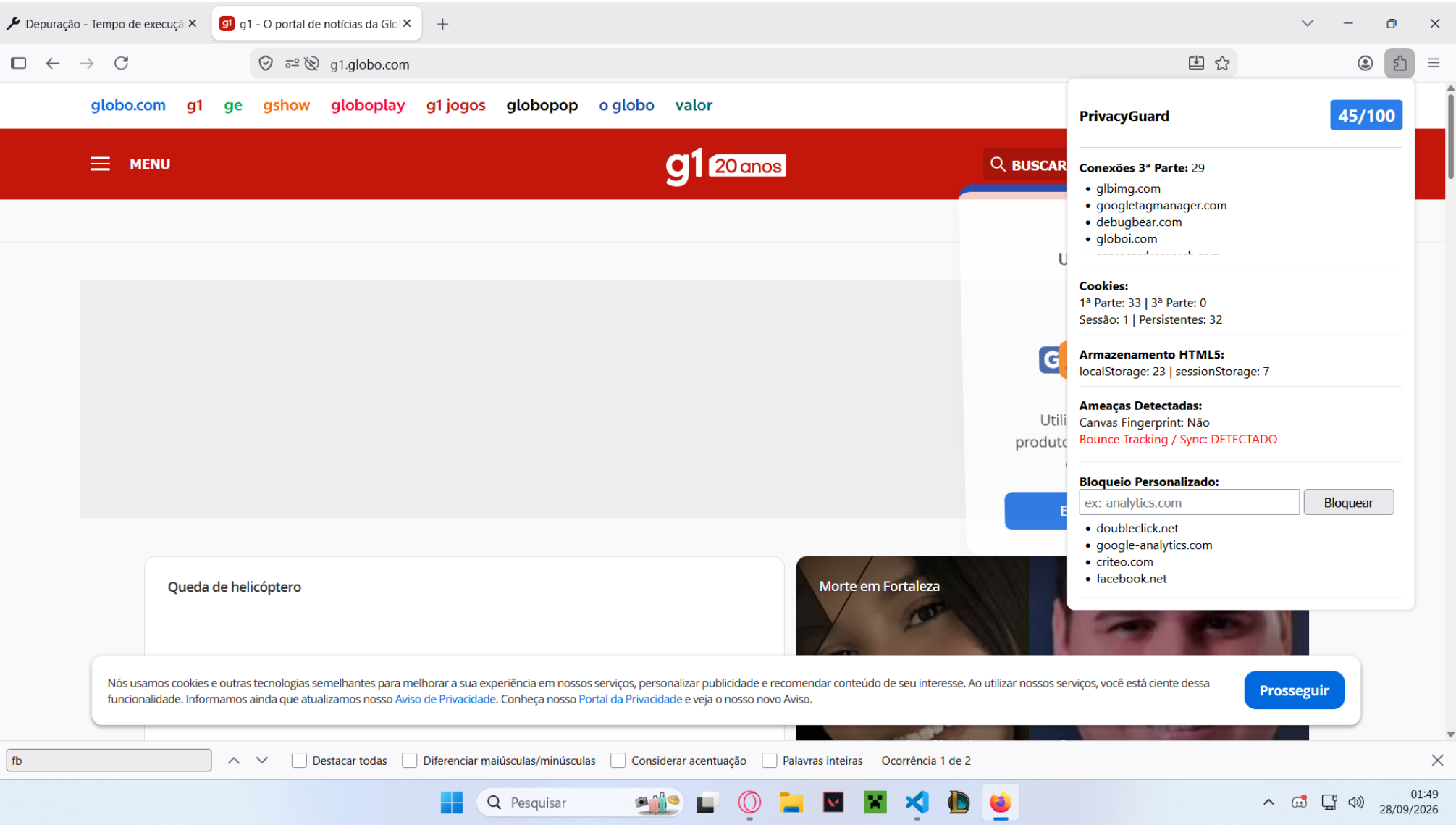


Figura 6. PrivacyGuard no G1: 29 conexões de terceira parte, 33 cookies e score 45/100.

Evidência 3.2 - UOL

The screenshot shows the UOL website interface. At the top, there is a navigation bar with links to INGRESSO.COM, BATE-PAPO, UOL HOST, PASSEI DIRETO, UOL PLAY, PAGBANK, and UOL ADS. Below this is the UOL logo and a search bar. The main content area features a large headline: "Sem provas, Flávio diz que CNBB articulou fake news sobre N. Senhora". Below the headline, there is a sub-headline: "Candidato de Placusa bispos de atuarem com o PT na disseminação de conteúdo". A red banner at the bottom right says "canal uol" and "AO VIVO".

The PrivacyGuard overlay is visible on the right side of the screen. It displays the following information:

- PrivacyGuard** (Score: 60/100)
- Conexões 3ª Parte: 17**
 - permutive.com
 - newsroom.bi
 - clarity.ms
 - globo.com
- Cookies:**
 - 1ª Parte: 0 | 3ª Parte: 0
 - Sessão: 0 | Persistentes: 0
- Armazenamento HTML5:**
 - localStorage: 0 | sessionStorage: 0
- Ameaças Detectadas:**
 - Canvas Fingerprint: Não
 - Bounce Tracking / Sync: DETECTADO
- Bloqueio Personalizado:**
 - ex: analytics.com
 - doubleclick.net
 - google-analytics.com
 - criteo.com
 - facebook.net

The Windows taskbar at the bottom shows the search bar with "Pesquisar", several application icons, and the system clock displaying "01:51 28/09/2026".

Figura 7. PrivacyGuard no UOL: 17 conexões de terceira parte, nenhum cookie/storage observado e score 60/100.

Evidência 3.3 - Mercado Livre

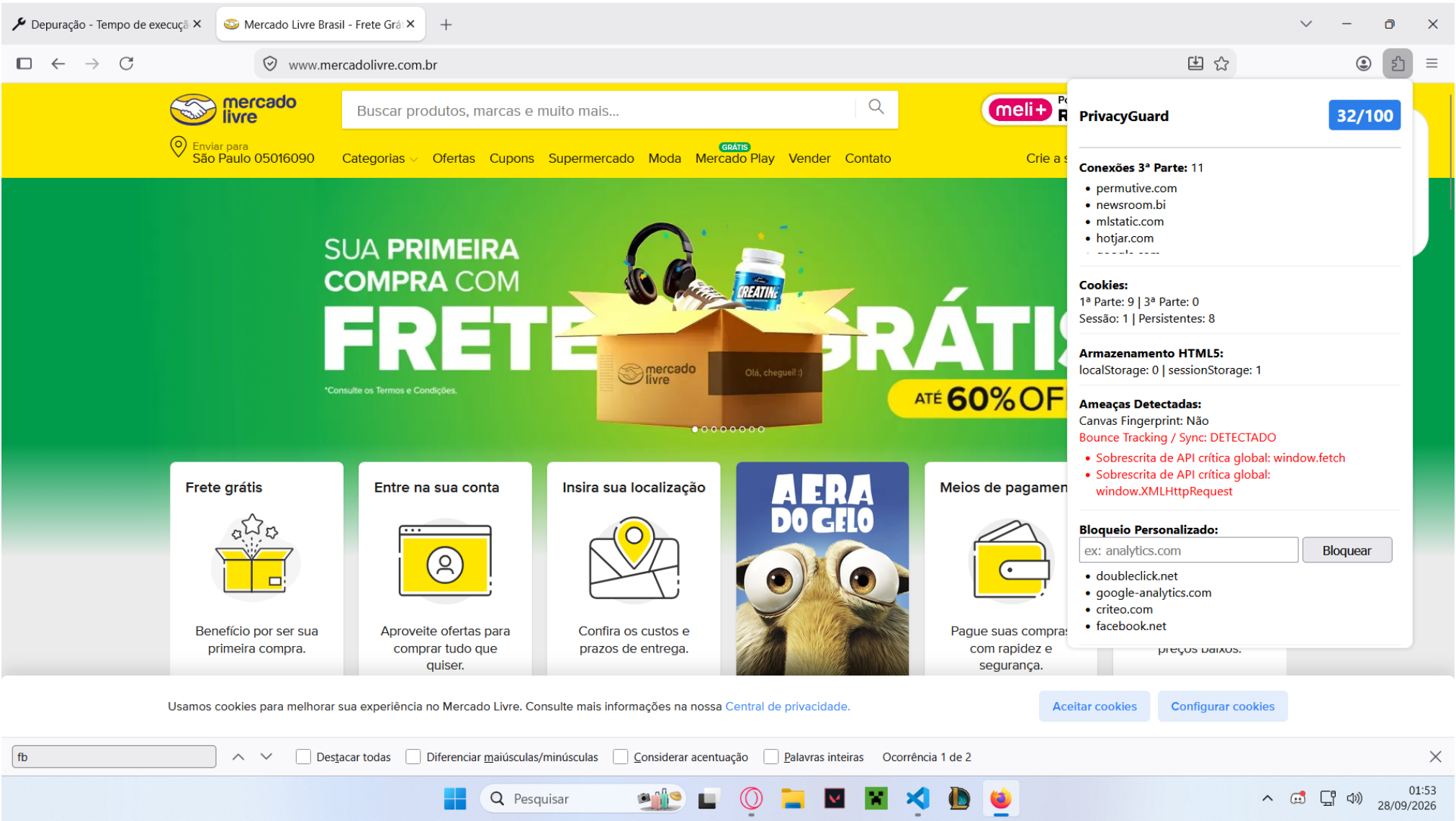


Figura 8. PrivacyGuard no Mercado Livre: 11 conexões, 9 cookies, hooking em fetch/XMLHttpRequest e score 32/100.

3.1 Reconciliação técnica das diferenças

Site	Leitura crítica
G1	O plugin contou 29 domínios externos, próximo aos 27 ad trackers do Blacklight, mas reportou zero cookies de terceira parte enquanto o Blacklight encontrou 14. Isso é compatível com diferenças de sessão, consentimento, particionamento de cookies e classificação: conexão externa não equivale necessariamente a tracker, e cookies podem ser bloqueados ou isolados pelo Firefox.
UOL	A maior divergência aparece no UOL: 17 conexões no plugin contra 67 trackers e 141 cookies no Blacklight. O print mostra a página ainda em carregamento e nenhum cookie/storage; execução prolongada, consentimento, rolagem e scripts tardios podem ampliar substancialmente o inventário do crawler. A confirmação exige a linha temporal do HAR.
Mercado Livre	O Blacklight classificou zero ad trackers e três cookies de terceiros, enquanto o plugin contou 11 domínios externos. Isso não é contraditório: o PrivacyGuard inclui CDNs, observabilidade e serviços corporativos. Já o alerta de hooking indica integridade alterada, mas não prova por si só sequestro malicioso; bibliotecas legítimas de APM e instrumentação também encapsulam APIs nativas.

Comparação com o uBlock Origin

O uBlock Origin decide bloqueios por listas e regras dinâmicas; o PrivacyGuard classifica comportamento e relação entre origens. Assim, o uBlock pode bloquear uma requisição conhecida antes que ela produza cookie ou storage, enquanto o plugin pode listar CDNs e serviços legítimos que nenhuma lista deveria bloquear. Uma reconciliação rastreador a rastreador requer exportar o logger do uBlock e cruzá-lo com o HAR por URL, initiator, status e instante.

Interpretação prudente de hooking. A substituição de `window.fetch` ou `XMLHttpRequest` é um indicador de instrumentação, não uma condenação automática. A severidade depende do script responsável, do domínio de destino, dos dados interceptados e do consentimento.

4. Metodologia do Privacy Score

A nota parte de 100 pontos e subtrai penalidades limitadas por categoria. O piso é zero:

$$\text{Score} = \max(0, 100 - P_{\text{req}} - P_{\text{cookie3p}} - P_{\text{cookiePers}} - P_{\text{canvas}} - P_{\text{bounce}} - P_{\text{storage}} - P_{\text{hijack}})$$

Critério	Peso	Justificativa
Domínios de 3ª parte	-3 por domínio; máx. -30	Cada entidade externa amplia a superfície de correlação e exposição.
Cookies de 3ª parte	-4 por cookie; máx. -20	Vetor clássico de rastreamento entre sites.
Cookies persistentes	-1 por cookie; máx. -10	Possibilitam reidentificação além da sessão atual.
Canvas fingerprinting	-15 fixos	Identificação silenciosa que independe de cookies.
Bounce tracking / sync	-10 fixos	Sincroniza identificadores por navegação e redirecionamento.
Abuso de HTML5 storage	-5 se localStorage > 5	Pode funcionar como mecanismo persistente de reidentificação.
Hooking de API crítica	-10 por API; máx. -20	Afeta a integridade do ambiente e permite observar tráfego assíncrono.

Comparação crítica com o Blacklight

Concordância. Ambos destacam que portais com ecossistemas publicitários e numerosos terceiros merecem escrutínio. Divergência. O Blacklight apresenta categorias de detecção e compara o resultado com uma amostra de sites; o PrivacyGuard produz nota cumulativa e inclui toda origem externa, storage e integridade de APIs. Por isso, o Mercado Livre pode receber 32/100 no plugin mesmo quando o Blacklight classifica zero ad trackers: os instrumentos medem conjuntos diferentes.

Limitação do score. A penalização por domínio não distingue finalidade, necessidade e controladoria, e o hooking recebe peso elevado mesmo quando decorre de observabilidade legítima. Uma evolução recomendada é ponderar reputação, categoria do domínio, consentimento, volume de dados e evidência de exfiltração.

5. Conclusão e pendências de entrega

O PrivacyGuard possui uma base funcional relevante: inventaria terceiros, cookies e storage; calcula score; oferece lista de bloqueio; e detecta alterações em APIs críticas. Os testes também demonstram limites concretos que precisam ser tratados antes de alegar cobertura completa de conceito A: falso negativo de canvas, falso negativo de bounce no teste dedicado, provável falso positivo de bounce em storage e classificação insuficiente de cookies de terceira parte.

Item obrigatório	Status evidenciado neste PDF
Prints do plugin nos testes	Incluídos: tracker, storage, canvas, bounce e query parameters.
Prints do plugin nos 3 sites	Incluídos: G1, UOL e Mercado Livre.
Metodologia de score	Incluída, com critérios, pesos, limites e crítica.
HAR dos 3 sites	Entregar separadamente. Não constava nos anexos recebidos.
Reconciliação rastreador a rastreador	Parcial. Exige URLs do HAR e exportação/logger do uBlock para conclusão verificável.
Tracker Blocking, Storage Partitioning e js-leaks	Sem prints anexados. São citados nos critérios de conceito B/A e devem ser acrescentados se realizados.

Referências e ferramentas

THE MARKUP. Blacklight: a real-time website privacy inspector. Metodologia disponível em: <https://themarkup.org/blacklight/2020/09/22/how-we-built-a-real-time-privacy-inspector>.

MOZILLA. WebExtensions APIs: webRequest, cookies e content scripts. Documentação disponível em: <https://developer.mozilla.org/docs/Mozilla/Add-ons/WebExtensions>.

DUCKDUCKGO. Privacy Test Pages. Páginas padronizadas utilizadas nos ensaios de tracker, storage, bounce e query parameters.

BROWSERLEAKS. Canvas Fingerprinting. Página complementar usada no ensaio ilustrado na Figura 3.

Documento preparado a partir dos resultados e capturas fornecidos pelo aluno. As correções de consistência refletem estritamente as evidências visíveis nos prints e os números do Blacklight transcritos no enunciado.